

Lineamiento para aplicaciones empresariales

1. Generalidades

Las **Aplicaciones Empresariales (Enterprise applications)** y los **Registros de Aplicación (App registration)** deberán ser creadas única y exclusivamente por los **ingenieros cloud del grupo de Servicios** en coordinación con los **ingenieros de seguridad cloud** del grupo de ciberseguridad y Arquitectura.

En **ambientes productivos**, el **personal del grupo de Identidades y Acceso** serán los únicos encargados de **asignar usuarios y grupos** a las aplicaciones empresariales que haya sido creadas como parte de los proyectos del Banco Bolivariano.

2. Estándares de autenticación permitidos por Entra ID

Banco Bolivariano solo admite los siguientes estándares:

- **OAuth 2.0 / OpenID Connect (OIDC)**: para autorización delegada. Un estándar de autorización que permite a las aplicaciones obtener acceso limitado a los recursos en nombre del usuario, utilizando tokens de acceso.
- **SAML 2.0** : para aplicaciones empresariales heredadas.

3. Tipos de cuentas compatibles

Para cumplir con el principio de mínimo privilegio y control de acceso, solo se permite **“single tenant”**, esto significa que solo los usuarios de tu organización pueden acceder a la aplicación.

No está permitido configurar **“multi-tenant”** o **“personal accounts”** (cuentas Microsoft personales).

[Home](#) > [App registrations](#) >

Register an application ...

* Name

The user-facing display name for this application (this can be changed later).

appmyapptest1 ✓

Supported account types

Who can use this application or access this API?

- ☒ Accounts in this organizational directory only (Banco Bolivariano C.A. only - Single tenant)
- ☐ Accounts in any organizational directory (Any Microsoft Entra ID tenant - Multitenant)
- ☐ Accounts in any organizational directory (Any Microsoft Entra ID tenant - Multitenant) and personal Microsoft accounts (e.g. Skype, Xbox)
- ☐ Personal Microsoft accounts only

4. Datos a compartir con tercero

4.1 Crear una aplicación empresarial con OAuth 2.0 (OpenID Connect)

Esta opción es ideal para aplicaciones modernas que usan tokens de acceso y autorización delegada. Ejemplo:

1. Portal de Entra ID:

<https://entra.microsoft.com> → “Identidad” → “Registros de aplicaciones” → “Nuevo registro”.

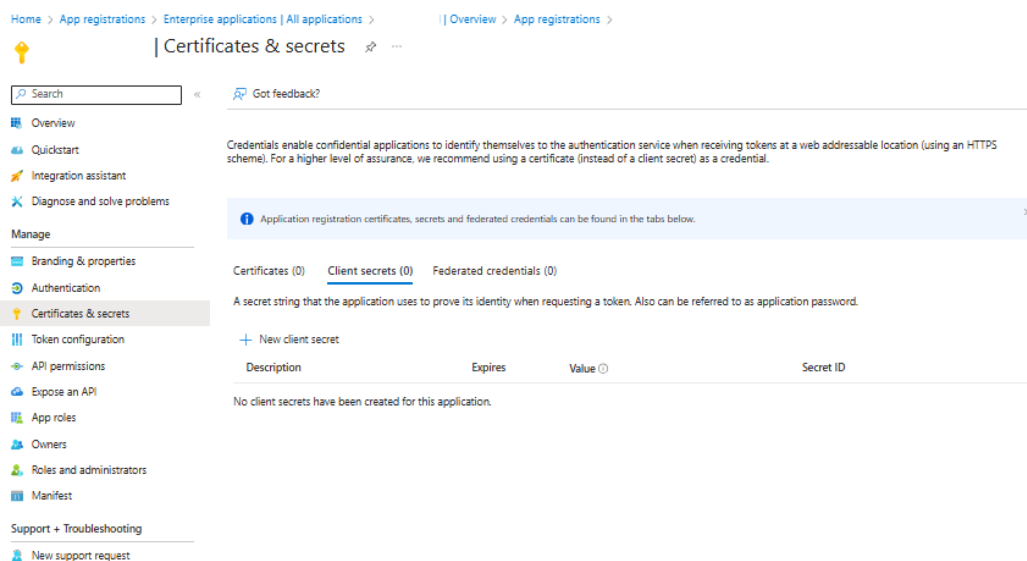
2. Completar los campos:

- **Nombre:** Nombre descriptivo de la app.
- **Tipos de cuenta:** Selecciona “Solo cuentas en este directorio organizativo (single tenant)”.
- **URI de redireccionamiento:** Agrega la URL donde se enviarán los tokens (por ejemplo, <https://miapp.com/auth/callback>).

3. Registrar la aplicación.

4. Configurar certificados y secretos:

- Ir a “Certificados y secretos”.
- Agregar un **secreto de cliente o certificado** (recomendado para mayor seguridad).



5. Configurar permisos de API:

- Ir a “Permisos de API”.
- Agregar permisos delegados o de aplicación según lo que necesite tu app (por ejemplo, User.Read).

Configured permissions

Applications are authorized to call APIs when they are granted permissions by users/admins as part of the consent process. The list of configured permissions should include all the permissions the application needs. [Learn more about permissions and consent](#)

+ Add a permission ✓ Grant admin consent for Banco Bolivariano C.A.

API / Permissions name	Type	Description	Admin consent requ...	Status
Microsoft Graph (1)				
User.Read	Delegated	Sign in and read user profile	No	***

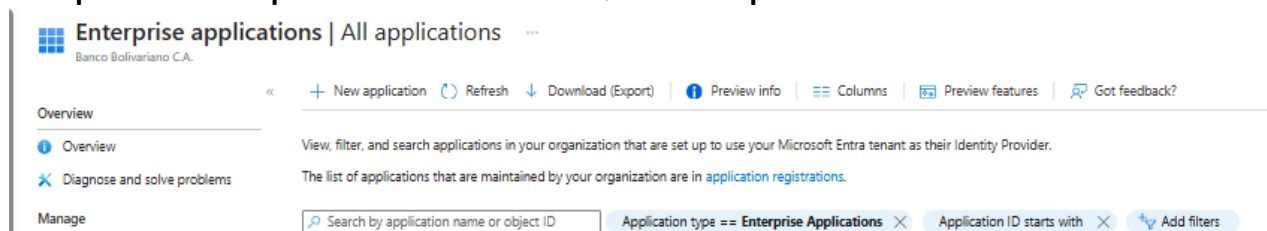
6. Copiar los valores necesarios:

- Application (client) ID
- Directory (tenant) ID
- Client secret o thumbprint del certificado
- Endpoints de autorización y token

4.2 Crear una aplicación empresarial con SAML 2.0

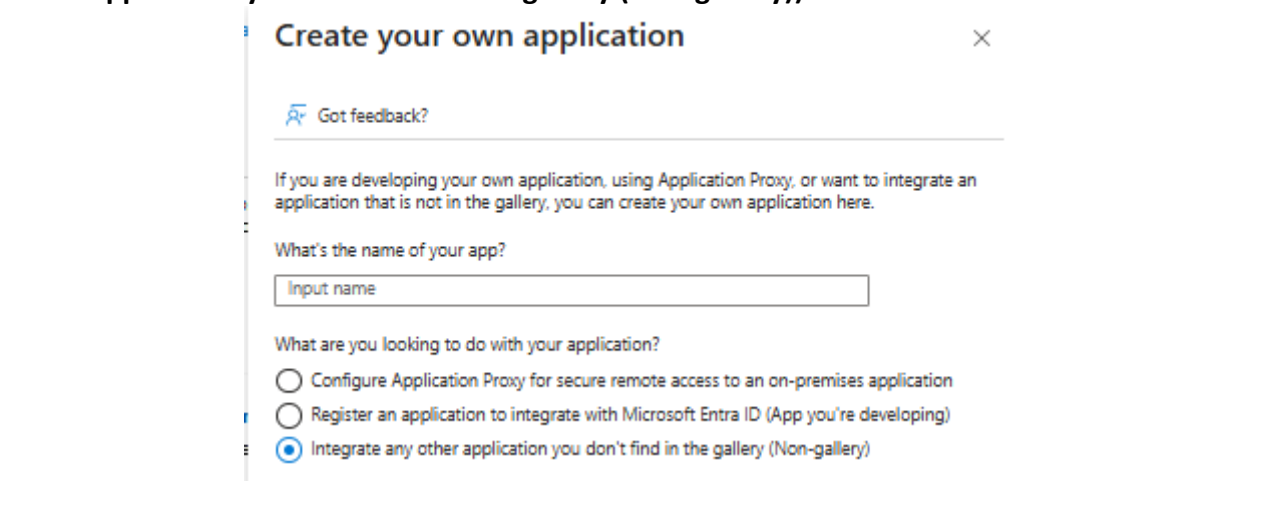
Esta opción es común para aplicaciones heredadas o SaaS que requieren SSO con SAML. Ejemplo:

1. “Aplicaciones empresariales” en Entra ID → “Nueva aplicación”.



2. Seleccionar “Aplicación no en galería”:

- Asigna un nombre.
- Selecciona “Integrar cualquier otra aplicación que no se encuentre en la galería” (Integrate any other application you don't find in the gallery (Non-gallery)).



Home > App registrations > Enterprise applications | All applications > bb_fs_cloud | Overview > App registrations > bb_fs_cloud | API permissions > Enterprise applications | All applications > Browse Microsoft Entra App Gallery

bbapptest1 | Overview

Enterprise Application

- Overview
- Deployment Plan
- Diagnose and solve problems
- Manage
 - Properties
 - Owners
 - Roles and administrators
 - Users and groups
 - Single sign-on
 - Provisioning
 - Application proxy
 - Self-service
 - Custom security attributes
- Security
 - Conditional Access
 - Permissions
 - Token encryption
- Activity

Properties

Name: **bbapptest1** [Copy to clipboard](#)

Application ID: **b277651d-e19a-4d31-a622-...**

Object ID: **1bf53c64-6fd0-4877-abd4-...**

Getting Started

- 1. Assign users and groups**
Provide specific users and groups access to the applications.
[Assign users and groups](#)
- 2. Set up single sign on**
Enable users to sign into their application using their Microsoft Entra credentials.
[Get started](#)
- 3. Provision User Accounts**
Automatically create and delete user accounts in the application.
[Get started](#)
- 4. Conditional Access**
Secure access to this application with a customizable access policy.
[Create a policy](#)
- 5. Self service**
Enable users to request access to the application using their Microsoft Entra credentials.
[Get started](#)

3. Configurar inicio de sesión único (SSO):

- En la sección “Inicio de sesión único”, selecciona SAML.

Home > App registrations > Enterprise applications | All applications > bb_fs_cloud | Overview > App registrations > bb_fs_cloud | API permissions > Enterprise applications | All applications > Browse Microsoft Entra App Gallery > bbapptest1

bbapptest1 | Single sign-on

Enterprise Application

- Overview
- Deployment Plan
- Diagnose and solve problems
- Manage
 - Properties
 - Owners
 - Roles and administrators
 - Users and groups
 - Single sign-on**
 - Provisioning
 - Application proxy
 - Self-service
 - Custom security attributes

Single sign-on (SSO) adds security and convenience when users sign on to applications in Microsoft Entra ID by enabling a user in your organization to sign in to every application they use with only one account. Once the user logs into an application, that credential is used for all the other applications they need access to. [Learn more](#).

Select a single sign-on method [Help me decide](#)

**Disabled**
Single sign-on is not enabled. The user won't be able to launch the app from My Apps.

**SAML**
Rich and secure authentication to applications using the SAML (Security Assertion Markup Language) protocol.

**Password-based**
Password storage and replay using a web browser extension or mobile app.

**Linked**
Link to an application and/or Office 365 app.

bbapptest1 | SAML-based Sign-on ...
Enterprise Application

Overview | Deployment Plan | Diagnose and solve problems

Manage

- Properties
- Owners
- Roles and administrators
- Users and groups
- Single sign-on**
- Provisioning
- Application proxy
- Self-service
- Custom security attributes

Security

- Conditional Access
- Permissions
- Token encryption

Activity

- Sign-in logs
- Usage & insights
- Audit logs
- Provisioning logs
- Access reviews

Upload metadata file | Change single sign-on mode | Test this application | Got feedback?

Set up Single Sign-On with SAML

An SSO implementation based on federation protocols improves security, reliability, and end user experiences and is easier to implement. Choose SAML single sign-on whenever possible for existing applications that do not use OpenID Connect or OAuth. [Learn more.](#)

Read the [configuration guide](#) for help integrating bbapptest1.

- #### 1 Basic SAML Configuration

Identifier (Entity ID) **Required**

Reply URL (Assertion Consumer Service URL) **Required**

Sign on URL **Optional**

Relay State (Optional) **Optional**

Logout Url (Optional) **Optional**
- #### 2 Attributes & Claims

⚠ Fill out required fields in Step 1

givenname	user.givenname
surname	user.surname
emailaddress	user.mail
name	user.userprincipalname
Unique User Identifier	user.userprincipalname
- #### 3 SAML Certificates

Token signing certificate	
Status	Active
Thumbprint	3E854A7A2AC83AF993C8843D1BD05E9C1C2883B9
Expiration	3/19/2030, 7:05:02 PM
Notification Email	rteran@bolivariano.com
App Federation Metadata Url	https://login.microsoftonline.com/381bee0c-a9ea...
Certificate (Base64)	Download
Certificate (Raw)	Download

4. Completar los campos de configuración SAML:

- **Identificador (Entity ID):** proporcionado por el proveedor.
- **URL de respuesta (Assertion Consumer Service URL).**
- **Formato del nombre de usuario:** por ejemplo, *user.userprincipalname*.

5. Descargar metadatos de Entra ID:

Proporciona al proveedor externo el archivo XML de metadatos o los valores:

- Issuer
- Login URL
- Certificado X.509

6. Asignar usuarios o grupos:

- Ir a "Usuarios y grupos" → asignar quién puede acceder a la app.

7. Probar la configuración:

- Usa la opción "Probar inicio de sesión" para validar la integración.

5. Restricciones

Todas las aplicaciones empresariales deben protegerse mediante políticas de acceso condicional, donde se debe restringir:

- MFA para todos los usuarios.
- Restringir el acceso por ubicación geográfica o IP.
- Bloquear acceso desde dispositivos no administrados.
- Aplica políticas de sesión (como expiración de tokens).
- Revisión de permisos periódica para detectar excesos.

6. Grupos de seguridad

Todas las aplicaciones empresariales deben tener **únicamente y exclusivamente grupos de seguridad configurado en la aplicación**, no se permite usuarios directamente asignados a la aplicación para mantener la administración centralizadas de los permisos por parte del equipo de Identidades y Accesos.

7. Certificados y client secrets

Las aplicaciones deben autenticarse con Entra ID usando uno de estos métodos:

Client secrets:

- Son cadenas generadas que actúan como contraseñas.
- Deben tener una expiración corta (máximo 6-12 meses).
- Se recomienda rotarlas automáticamente.
- Implementa políticas de rotación automática de secretos y certificados.
- Nunca almacenes client secrets en código fuente o archivos de configuración sin cifrado.
- Usa Azure Key Vault para guardar secretos y certificados de forma segura.
- No reutilizar **client secrets** entre múltiples aplicaciones.

Certificados (X.509):

- Más seguros que los secrets.
- Se cargan en formato .cer o .pem.
- Deben tener expiración definida y ser renovados antes de su vencimiento.
- Tienen mayor longitud y complejidad.
- Pueden integrarse con HSM (Hardware Security Modules) o Azure Key Vault.
- Certificados deben renovarse antes de su vencimiento (idealmente 30 días antes).
- Usar alertas automáticas para expiraciones próximas.